Day 3: Where this lives in the real world

For each idea from today, the real tool or standard people use, and the question to ask a vendor or a project team. Named products are examples of a category, not recommendations.

Today's idea	Real-world examples	Question to ask
Did that already happen? (idempotency, event log)	Payment APIs that take an idempotency key: Stripe documents an `Idempotency-Key` header on POST requests, keeps results for at least 24 hours and replays the stored response. Workflow engines that persist state so a restart resumes rather than repeats (for example Temporal, AWS Step Functions)	Does the tool accept a key? What does it return on a retry? How long is the key kept? What happens if the same key arrives with different details?
Fail loudly	Retry budgets and circuit breakers in libraries you may already use (for example resilience4j for Java, Polly for .NET)	After how many failures, or how many minutes, does the run stop and who is paged? What does the final message say about what was not done?
Record what is running (AI-BoM)	CycloneDX ML-BOM and the AI profile in SPDX 3.0 as starting formats. Pinned model identifiers: provider APIs and cloud catalogues such as Amazon Bedrock use dated or versioned model IDs, and aliases can move	Do we use a pinned version or an alias? Where is the record, and who owns each line?
Spot the difference (drift)	A diff of a record against its baseline, on a schedule and on every change. Your existing test tooling plus a labelled evaluation set, re-run after any change	What re-runs when the provider changes something? Who reads the release notes?
Gateway filter	Amazon Bedrock Guardrails (the `ApplyGuardrail` API works on text from any model, with source INPUT or OUTPUT). Azure AI Content Safety Prompt Shields (user-prompt and document attacks). Your own AI firewall or gateway product	What does it miss? Is the verdict enforced in code, or advisory? Where are its decisions logged?
Tool sandbox and policy	Least-privilege cloud roles. Open Policy Agent (a CNCF policy engine) with default deny. Your MCP gateway from Day 2	If the agent is talked into asking, what still says no?
Output schema	JSON Schema or Pydantic validation in your own code, whatever structured-output mode the model API offers	Is the output checked on our side before anything acts on it?
Trace and revision	OpenTelemetry GenAI semantic conventions (still marked Development; moved to their own repository in June 2026), supported by several observability vendors	Can an incident be tied to the exact configuration that was running?
Escalation triggers	The queue your operations team already works. A trigger written so it can be run	Who owns it, how fast must they respond, and how do we test it?

Frameworks and rules to name

- **OWASP Top 10 for LLM Applications (2026 edition, August 2026)** and **OWASP Top 10 for Agentic Applications (published 9 December 2025).** The first treats the model inside an application; the second covers agents with tools and memory. "Excessive agency" is the OWASP name for what the tool sandbox limits.
- **Agents Rule of Two (Meta, 31 October 2025).** Until prompt injection can be reliably detected, an agent session should have no more than two of: it processes untrusted input; it can reach sensitive systems or private data; it can change state or communicate outside. If it needs all three, a human approves. Closely related to Simon Willison's "lethal trifecta" from Day 2.
- **DORA (applies since 17 January 2025).** Financial entities must maintain a register of information on contractual arrangements with ICT third-party providers (Article 28(3)). A configuration record that names the model provider, the platform prompt owner and the tool servers is a natural input. Confirm dates and scope with your compliance team before relying on

this summary.

Sources

- Stripe, Idempotent requests: https://docs.stripe.com/idempotency
- Amazon Bedrock Guardrails, ApplyGuardrail: https://builder.aws.com/content/2j63w0yGI17kuL1TkUdI0GPddDL
- Microsoft, Prompt Shields: https://learn.microsoft.com/en-us/azure/ai-services/content-safety/concepts/jailbreak-detection
- OpenTelemetry, GenAI agent spans: https://opentelemetry.io/docs/specs/semconv/gen-ai/gen-ai-agent-spans
- Dash0, OpenTelemetry GenAI conventions explained (status, June 2026 move): https://www.dash0.com/knowledge/opentelemetry-genai-semantic-conventions-explained
- OWASP GenAI Security Project, Top 10 for Agentic Applications: https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/
- Cloud Security Alliance note on the 2026 LLM Top 10: https://labs.cloudsecurityalliance.org/research/csa-research-note-owasp-genai-top10-2026-agent-control-stand/
- Simon Willison on the Agents Rule of Two: https://simonw.substack.com/p/new-prompt-injection-papers-agents
- DORA, Article 28(3) register of information: https://docs.modulos.ai/frameworks/dora/faq